STHIROS · RISK · INFORMATION SYSTEMS AUDIT · BFSI

STHIROS
Strategy. Risk. Cyber. AI.



Validating access and control integrity across a lender's core systems, end to end

A growing NBFC engaged Sthiros to run an Information Systems Audit across its four-application lending stack, an audit that surfaced 76 ghost users and 1,746 segregation-of-duties violations no internal review had caught.

Client	Product Deployed	Sector	Geography
A Leading NBFC	**Information Systems Audit, RBI Master Direction, Application Review & General IT Controls**	**BFSI, NBFC**	**India**

The Challenge:

When internal controls are left to audit themselves

This NBFC runs core lending across four applications, LOS, LMS, D365, and HRMS, on AWS with GitLab repositories. As the workforce scaled and an LMS migration ran in parallel, access reviews and segregation of duties were handled internally, with no independent baseline to test against.

No Independent Baseline

Access reviews and incident handling were self-assessed, with real exposure untested.

Ghost Access

76 live IDs from ex-employees and migration orphans sat active in the system.

Segregation Violations

1,746 HRMS initiator-approver conflicts left maker-checker controls broken at scale.

Regulator Exposure

RBI's ITGRC Direction demanded proof policies were operating, not just written.

Scale Outpacing Governance

A lack of proactive visibility into container status and Last Free Days resulted in avoidable demurrage and detention charges.

Incident Handling Gaps

A lost laptop was resolved over email,| with no formal classification or response.

"Four critical applications. Multiple cloud environments. A workforce in rapid growth. And a control environment that had never been independently validated end-to-end."

The Solution:

Three layers, no shortcuts, every finding tested twice

Sthiros ran a structured, three-layer audit across policy, live control testing, and physical verification, converting every gap into a validated, owned action.

Every one of the 22 findings was classified by severity and gap type, then paired with a named owner and a committed date.

"A four-application lending stack needed more than a policy review. It needed live testing of every access right and every conflict, before RBI came asking."

The Methodology

1 Policy & Documentation Review

Every IT governance policy, security policy, BCP/DR framework, access control matrix, and VAPT report checked against RBI Master Direction requirements, line by line.

2 Evidence-Based Control Testing

Access reviews, user-role mappings, and segregation-of-duties conflicts tested through systematic role analysis across LOS, LMS, D365, and HRMS, not taken on the institution's word.

3 Live System & Physical Verification

15 laptops physically checked for hardening and DLP configuration. Passwords tested live. 83+ application scenarios run, including the KYC input failures that surfaced in LOS. Incident logs checked against what actually happened, not what was reported.

What This Means

Ghost users don't deactivate themselves.

Role design creates the conflict.

An untested plan isn't a plan.

Outcomes

76

Ghost users deactivated

Live, unmonitored access points into loan processing systems removed at the source.

1,746

SoD conflicts mapped

HRMS initiator-approver conflicts mapped to specific roles, users, and modules.

22

Findings, 100% owned

Every finding classified, assigned a named owner, and given a committed ETA.

4

System enhancements

Proactive recommendations delivered beyond the audit mandate.

Get in touch

Is your control environment tested, or just documented?

Speak to Sthiros about what a structured IS audit can unlock for your technology ecosystem.

Connect with us:
sthiros.com

STHIROS
Strategy. Risk. Cyber. AI.